RESTRICTED

QAYRAWAN INFORMATION SYSTEMS

Data Protection Procedure

Procedure · Implementing document for the Data Protection Policy QIS-POL-001

Document ID	**QIS-PRC-001**
Version	0.2 (Draft)
Date	10 November 2026
Classification	Restricted
Sharing signal	Amber · TLP:AMBER

Prepared by Naif Alsalem, GRC Lead

Issued in Arabic and English; if they conflict, the Arabic text prevails. QIS is a fictional company: its people and clients are invented for a professional portfolio by Naif Alsalem. The regulators and regulations cited are real.

RESTRICTED

Document information

Document name	Data Protection Procedure
Document code	QIS-PRC-001
Parent policy	Data Protection Policy — QIS-POL-001 (version 0.3)
Document owner	GRC Lead — Naif Alsalem
Prepared by	Naif Alsalem — GRC Lead
Document version	0.2 (Draft)

Sharing signal (Traffic Light Protocol)

This document is marked under the Traffic Light Protocol (TLP) used in National Cybersecurity Authority documents at **Amber (TLP:AMBER)**. It may not be circulated beyond that level without the owner's approval.

● **Red** TLP:RED	Personal and confidential to the recipient only: it may not be shared with anyone inside or outside the recipient's organization beyond the stated recipients.
● **Amber** TLP:AMBER	**Limited sharing: the recipient may share it within their own organization, only with the people concerned and those who need to act on it. — the level set for this document**
● **Green** TLP:GREEN	Sharing within the same community: it may be shared within the organization, related organizations or the same sector, but not through public channels.
● **White** TLP:WHITE	Unlimited.

RESTRICTED

Change log

Version	Date	Changed by	Reason for change
0.1	10 Nov 2026	Naif Alsalem	First version: five procedures implementing the Data Protection Policy, including contract review and third-party access and data sharing.
0.2	10 Nov 2026	Naif Alsalem	References to subdomain 2-7 updated to the 2024 edition of the Essential Cybersecurity Controls. English version translated from the Arabic lead text.

Document approval

Role	Job title	Name	Date	Signature
Owner	GRC Lead	Naif Alsalem	—	—
Reviewer	Chief Technology Officer	Reem Al-Otaibi	—	—
Reviewer	Chief Financial Officer (contracts and HR)	Majed Al-Qahtani	—	—
Approver	Chair, Cybersecurity Steering Committee	Faisal Al-Harbi	—	—

Review schedule

Review frequency	Last review	Next review
With every update to the parent policy, and at least once a year	—	November 2027

RESTRICTED

Document classification

Top Secret	The document is classified "Top Secret" if unauthorized access to it or disclosure of it or its content would cause serious damage that cannot be remedied or repaired.
Secret	The document is classified "Secret" if unauthorized access to it or disclosure of it or its content would cause serious damage. This applies to sensitive information that defines how QIS operates.
Restricted	**The document is classified "Restricted" if unauthorized access to it or disclosure of it or its content would cause limited damage. This applies to information not approved for general circulation outside QIS.**
Public	The document is classified "Public" when unauthorized access to it or disclosure of its content would have no effect on QIS. This applies to documents approved for public release.

Confidentiality of the document

This document is a Qayrawan Information Systems document classified Restricted. It may be circulated only to QIS staff and to the government clients under contract who need to see it. It may not be published, changed or shared, in whole or in part, with anyone unauthorized without the prior written approval of the document owner.

RESTRICTED

Contents

1. Purpose
2. Scope
3. Relation to the parent policy
4. Roles in carrying out the procedures
5. Procedure map
6. Procedure 1: Review and approve cybersecurity requirements in contracts
7. Procedure 2: Manage third-party access and data sharing
8. Procedure 3: Classify and handle data
9. Procedure 4: Respond to data breaches and data subject requests
10. Procedure 5: Retain, return and securely dispose of data
11. What the procedures need to run
12. Compliance indicators
13. References

RESTRICTED

1. Purpose

This document sets out the steps that turn the clauses of the Data Protection Policy into day-to-day work that can be measured and audited: who owns each step, what it must produce, how long it takes, and which records must be kept.

2. Scope

These procedures apply to every QIS department, its staff and contractors, to every contract and agreement with clients and third parties, and to all data QIS owns or processes for its clients, across its whole life cycle.

3. Relation to the parent policy

This document comes from the Data Protection Policy QIS-POL-001 and creates no obligations beyond it. Where they conflict, the policy prevails. Each procedure lists the policy clauses it carries out, and definitions are read from the policy rather than repeated here.

RESTRICTED

4. Roles in carrying out the procedures

Role	Responsibility in these procedures
GRC Lead (personal data protection officer)	Runs these procedures, reviews the security requirements in contracts, keeps the data sharing log and the record of processing activities, and coordinates with controllers.
Security Operations and Engineering	Checks screening results, monitors data loss prevention, and leads the response to data breaches with the managed security operations centre.
Chief Technology Officer	Grants and removes access, applies encryption, separates environments, masks data and carries out secure disposal.
Chief Financial Officer	Manages contracts and purchasing, and requests contractor screening through HR.
Head of Service Delivery	Passes on clients' documented instructions, obtains their approvals, and notifies them of incidents.
Data owner	Sets the data's classification and approves access to it and sharing of it. For client data this is the client, represented by the Head of Service Delivery.
Requesting departments	Submit complete contracting and sharing requests, and follow the data handling rules.

5. Procedure map

The five procedures cover the data life cycle and QIS's relationship with third parties in this order:

1 Contract	2 Access and sharing	3 Classify and handle	4 Respond	5 Dispose
Security requirements in contracts	Screening, access and the sharing log	Classification, labelling and masking	Data breaches and data subject requests	Return and secure disposal

Procedure	Name	Section	Policy clauses
1	Review and approve cybersecurity requirements in contracts	6	4-1-1 · 4-1-2 · 4-1-3 · QIS-4-1-2 · QIS-4-1-7
2	Manage third-party access and data sharing	7	QIS-4-1-1 · QIS-4-1-3 to QIS-4-1-6 · QIS-4-1-8 to QIS-4-1-10

RESTRICTED

Procedure	Name	Section	Policy clauses
3	Classify and handle data	8	2-7-2 · QIS-2-7-1 to QIS-2-7-4 · subdomain 2-8
4	Respond to data breaches and data subject requests	9	QIS-2-7-5 · QIS-9.3.1 · QIS-9.3.2 · QIS-9.5.1
5	Retain, return and securely dispose of data	10	QIS-2-7-6 · QIS-4-2-3 · QIS-9.1.1

RESTRICTED

6 Procedure 1: Review and approve cybersecurity requirements in contracts

Policy clauses implemented: 4-1-1, 4-1-2, 4-1-3, QIS-4-1-2, QIS-4-1-7

Procedure owner	Frequency	Steps	Reference duration
GRC Lead	Every new, renewed or changed contract	6 steps	About 10 working days

6.1 Objective

To make sure every contract and agreement with clients and third parties includes the approved cybersecurity and data protection requirements before it is signed, protecting QIS's and its clients' data and meeting legal requirements.

6.2 Frequency and scope

- New, renewed or changed contracts with suppliers, service providers, consultants and contractors.
- Client contracts under which QIS processes the client's data.
- Start event: a request to create, renew or change a contract is received.
- End event: the contract is approved with the requirements included, and archived.

6.3 Procedure steps

#	Step	Performed / approved by	Consulted / informed	Output	Time
1	Receive the contracting request with the service scope and the type of data the third party will access.	Requesting department · Finance Approves: Chief Financial Officer	GRC	**Request ready for review**	Day 0
2	Set the cybersecurity requirements by service type and data classification, and assess the third party's risk for outsourcing and managed services.	GRC Approves: GRC Lead	SecOps · data owner	**Requirements list and risk assessment**	3 working days

RESTRICTED

#	Step	Performed / approved by	Consulted / informed	Output	Time
3	Add the requirements to the contract: confidentiality, secure deletion with proof, incident notification, screening, processing inside the Kingdom, retention and the service level agreement.	Finance Approves: Chief Financial Officer	GRC	**Updated draft contract**	3 working days
4	For client contracts: agree data processing clauses with the client (purpose, scope, instructions, use of other parties, return and disposal).	Service Delivery Approves: Head of Service Delivery	Client · GRC	**Agreed processing clauses**	Per client
5	Review the security clauses against the policy and controls, and issue the security approval.	GRC Approves: GRC Lead	Finance	**Security approval of the contract**	2 days
6	Approve, sign and archive the contract, inform those concerned, and record it in the third-party register.	Finance Approves: Chief Executive Officer	GRC · SecOps	**Signed, archived contract**	2 days

6.4 Mandatory controls

- No contract that includes access to data is signed without a documented security approval.
- Current contracts missing the requirements are reviewed within a remediation period set by the Steering Committee.
- Managed service operations centres that work through remote access from outside the Kingdom are not accepted.
- QIS does not use another party to process a client's data without the client's written approval.

6.5 Records to keep

Contracting request, requirements list, third-party risk assessment, security approval, signed contract, confidentiality agreement, third-party register.

RESTRICTED

7 Procedure 2: Manage third-party access and data sharing

Policy clauses implemented: QIS-4-1-1, QIS-4-1-3 to QIS-4-1-6, QIS-4-1-8 to QIS-4-1-10

Procedure owner	Frequency	Steps	Reference duration
Security Operations and Engineering	Every access or sharing request	7 steps	About 5 working days

7.1 Objective

To make sure third parties' access to data, and the sharing of data with them, is secure and recorded, with the extra controls applied on highly sensitive projects.

7.2 Frequency and scope

- All third parties and contractors authorized to access QIS's or its clients' data or systems.
- Projects the client classifies as highly sensitive.
- Start event: the contract is approved and access or data sharing is requested.
- End event: access is removed, proof of secure deletion is received and the sharing record is closed.

7.3 Procedure steps

#	Step	Performed / approved by	Consulted / informed	Output	Time
1	Confirm the contract is approved and screen the third party's staff before granting any access.	SecOps · Finance Approves: Security Operations Lead	Data owner	**Screening results**	3 working days
2	Grant access on least privilege and for a set period, with named accounts and multi-factor authentication.	IT Approves: Chief Technology Officer	System owner	**Access enabled**	1 day
3	Review the sharing request: justification, reclassification to the lowest level, masking or scrambling where needed, and approvals for transfer outside the Kingdom if any.	Data owner · GRC Approves: Authorized person	SecOps	**Sharing approval**	2 days

RESTRICTED

#	Step	Performed / approved by	Consulted / informed	Output	Time
4	Share the data through approved encrypted channels, and record it in the data sharing log.	IT Approves: Data owner	GRC	**Sharing record**	1 day
5	For highly sensitive projects: prepare the dedicated devices, the closed room and its entry and exit controls, and monitor compliance throughout the project.	SecOps · IT Approves: Steering Committee	Client · project manager	**Approved secure workspace**	Before start
6	Review third parties' active access, and follow up their duty to report incidents.	SecOps Approves: Security Operations Lead	System owners	**Review report**	Quarterly
7	End access when it is no longer needed or the contract ends, receive proof of secure deletion, and close the sharing record.	IT · GRC Approves: Chief Technology Officer	Finance · data owner	**Proof of removal and deletion**	Within 24 hours

7.4 Mandatory controls

- No access is granted before screening is complete and a confidentiality agreement is signed.
- Shared accounts may not be used to access client data.
- No data is shared without a record in the sharing log.
- No electronic devices may enter the closed room, and no devices, storage media or documents may leave it.

7.5 Records to keep

Screening results, access requests, data sharing log, sharing and transfer approvals, closed-room entry logs, proof of removal and deletion.

RESTRICTED

8 Procedure 3: Classify and handle data

Policy clauses implemented: 2-7-2, QIS-2-7-1 to QIS-2-7-4, subdomain 2-8

Procedure owner	Frequency	Steps	Reference duration
Chief Technology Officer	Every new system or data set / annually	6 steps	About 7 working days

8.1 Objective

To make sure every data set is classified and has an owner before it is used, that storage, transfer and sharing rules apply by classification, and that real personal data is not used in non-production environments.

8.2 Frequency and scope

- Every new or hosted system that holds data.
- Every new data set received from a client.
- The annual classification review, and whenever the nature of the data changes.
- Start event: a request to run a system, or new data is received.
- End event: a documented classification with its controls applied.

8.3 Procedure steps

#	Step	Performed / approved by	Consulted / informed	Output	Time
1	List the data in the system, name its owner, and ask the client for its classification of its data.	IT · Service Delivery Approves: Data owner	GRC	**Data list and owner**	2 days
2	Set the classification level, record it in the asset register, and label the data and documents with it.	Data owner Approves: Data owner	GRC	**Documented classification**	2 days
3	Update the record of processing activities if the data includes personal data.	GRC Approves: Personal data protection officer	Service Delivery	**Updated record of activities**	1 day
4	Apply the classification's controls: encryption at rest and in transit, hosting location and access rights.	IT Approves: Chief Technology Officer	SecOps	**Proof the controls are applied**	3 working days

RESTRICTED

#	Step	Performed / approved by	Consulted / informed	Output	Time
5	Mask or synthesize data before copying it to development or test environments.	IT · Development Approves: Chief Technology Officer	GRC	**Masked test data**	Before copying
6	Check application in the periodic review, and reclassify when the nature of the data changes.	GRC Approves: GRC Lead	Data owners	**Review report**	Annually

8.4 Mandatory controls

- No system holding Restricted data or higher runs before its classification is documented.
- Data in transit is always encrypted with TLS 1.2 or later.
- Real personal data is not copied to a non-production environment without the controller's written approval.
- Encryption keys are kept apart from the data.

8.5 Records to keep

Data list and owner, classification record, record of processing activities, proof of encryption and hosting, exception approvals, review reports.

RESTRICTED

9 Procedure 4: Respond to data breaches and data subject requests

Policy clauses implemented: QIS-2-7-5, QIS-9.3.1, QIS-9.3.2, QIS-9.5.1

Procedure owner	Frequency	Steps	Reference duration
Security Operations and Engineering	Every breach or request	7 steps	Client notified within 24 hours

9.1 Objective

To detect and contain data breaches and notify the controller in time to meet the legal reporting deadline, and to pass data subject requests to the controller without delay, within the Incident Response Plan QIS-IRP-001.

9.2 Frequency and scope

- Any actual or suspected breach of QIS's or its clients' data, including data loss prevention alerts.
- A report from a third party of an incident affecting data QIS shared.
- Any request that reaches QIS from a data subject.
- Start event: a breach is detected or a report or request is received.
- End event: the incident is closed or the request is passed on and recorded.

9.3 Procedure steps

#	Step	Performed / approved by	Consulted / informed	Output	Time
1	Detect the event through data loss prevention, the managed security operations centre or a report, and log it.	SecOps Approves: Security Operations Lead	GRC	**Incident log**	Hour 0
2	Assess the incident: the data affected and its classification, the number of people affected and the client concerned, and rate its severity under QIS-IRP-001.	Incident lead · GRC Approves: Incident lead	IT	**Incident assessment**	Within 4 hours
3	Contain it: close the leak channel, remove affected access, and preserve evidence.	SecOps · IT Approves: Incident lead	Third party if involved	**Containment actions**	At once

#	Step	Performed / approved by	Consulted / informed	Output	Time
4	Notify the controller concerned of every breach involving personal data, without waiting for a harm assessment, with what it needs to notify the Saudi Data and AI Authority within 72 hours.	Service Delivery · data protection officer Approves: Chief Executive Officer	Steering Committee	**Documented client notice**	Within 24 hours
5	Fix the root cause, update the risk register, and hold a lessons-learned session.	SecOps · GRC Approves: Incident lead	Steering Committee	**Closure report**	10 working days
6	Data subject requests: log the request and pass it to the controller, without answering it directly unless the controller instructs QIS to.	GRC Approves: Personal data protection officer	Service Delivery	**Recorded referral**	Within 2 working days
7	Carry out what the controller asks to meet the request (extract, correct or destroy data), and record it.	IT Approves: Chief Technology Officer	GRC	**Proof of completion**	Per client instructions

9.4 Mandatory controls

- Evidence is preserved before any action that could destroy it.
- Every personal data breach is treated as reportable to the controller.
- QIS does not notify data subjects or authorities directly unless the controller instructs it or the law requires it.
- Incident and request records are kept for at least twelve months.

9.5 Records to keep

Incident log, assessment, containment and evidence log, client notice, closure report, data subject request log and referrals.

RESTRICTED

10 Procedure 5: Retain, return and securely dispose of data

Policy clauses implemented: QIS-2-7-6, QIS-4-2-3, QIS-9.1.1

Procedure owner	Frequency	Steps	Reference duration
Chief Technology Officer	Quarterly / when a contract ends or media is retired	6 steps	About 10 working days

10.1 Objective

To make sure data is not kept beyond its set period, that a client's data is returned when the contract ends, and that data and storage media are securely disposed of and the disposal recorded.

10.2 Frequency and scope

- Data past its retention period.
- A client's data when the contract ends or is terminated.
- Retired storage media and devices.
- Start event: a retention period or contract ends, or media is retired.
- End event: a disposal certificate is issued and the records are updated.

10.3 Procedure steps

#	Step	Performed / approved by	Consulted / informed	Output	Time
1	List the data past its retention period from the record of processing activities, or the data of a client whose contract has ended.	GRC Approves: Personal data protection officer	IT	**Disposal or return list**	Quarterly
2	Obtain the data owner's approval, or the client's written instructions, to return or dispose of the data.	Service Delivery Approves: Data owner	GRC	**Documented approval**	5 working days
3	Return the client's data in a usable format over an encrypted channel, and record receipt.	IT Approves: Chief Technology Officer	Service Delivery	**Proof of return**	Per contract

RESTRICTED

#	Step	Performed / approved by	Consulted / informed	Output	Time
4	Dispose of the data in QIS's and the cloud provider's environments and their backups so it cannot be recovered.	IT Approves: Chief Technology Officer	SecOps	**Disposal log**	3 working days
5	Dispose of retired storage media by secure wiping or physical destruction, and obtain proof of disposal from the supplier.	IT Approves: Chief Technology Officer	Finance	**Media disposal proof**	On retirement
6	Issue a disposal certificate for Restricted data and higher, and update the asset register and the record of processing activities.	GRC Approves: GRC Lead	Client on request	**Disposal certificate**	2 days

10.4 Mandatory controls

- No record under a legal retention period is disposed of before it expires, and no evidence of an open incident is destroyed.
- Disposal covers backups and the provider's copies, not only the primary environment.
- A disposal certificate is issued for every disposal of Restricted data or higher.
- Data is returned only through an approved encrypted channel.

10.5 Records to keep

Disposal and return lists, owner and client approvals, proof of return, disposal logs, media disposal proof, disposal certificates.

RESTRICTED

11. What the procedures need to run

11.1 Systems and tools

Tool / system	Purpose	Procedures
Third-party and contract register	Tracks contracts, their security requirements and screening	1, 2
Data sharing log	Records every sharing, its approvals and its closure	2
Asset register and record of processing activities	Classification, owner and retention periods	3, 5
Data loss prevention tools	Detect sensitive data leaving through email, cloud storage and devices	4
Key vault and masking tools	Manage encryption keys and mask test data	3
Secure wiping tools	Dispose of data and storage media	5

11.2 Approvals matrix

Decision	Approved by
Security approval of a contract	GRC Lead
Signing a contract that includes access to client data	Chief Executive Officer
Sharing Restricted data or higher with a third party	Data owner, and the controller for client data
Transferring data outside the Kingdom	The controller in writing, with the authorized person at QIS
Using real data in a non-production environment	The controller in writing, with the GRC Lead
Approving the workspace for a highly sensitive project	Cybersecurity Steering Committee

RESTRICTED

12. Compliance indicators

Code	Indicator	Target	Procedure
PRC-01	Contracts given a security approval before signing	100%	1
PRC-02	Third-party access granted after screening was complete	100%	2
PRC-03	New systems with their data classified before going live	100%	3
PRC-04	Data breaches reported to the client within 24 hours	100%	4
PRC-05	Disposals documented with a disposal certificate	100%	5

13. References

Type	Code	Reference
Internal	QIS-POL-001	Data Protection Policy (parent policy)
Internal	QIS-IRP-001	Incident Response Plan
Internal	QIS-RR-001	Risk Register
Internal	QIS-PRF-001	Company Profile and Scope
External	ECC-2:2024	Essential Cybersecurity Controls — National Cybersecurity Authority
External	DCC-1:2022	Data Cybersecurity Controls — National Cybersecurity Authority
External	PDPL	Personal Data Protection Law and its implementing regulation

RESTRICTED